

INGENIERÍA DE SOFTWARE II

ACTIVIDAD 8

Fundamentos del proceso de pruebas

UNA VULNERABILIDAD REAL EN ENLYCE

Cómo la encontramos, qué permitía y cómo quedó corregida

Samuel Andres Escobar Saldarriaga

Trabajo individual · 27 de septiembre de 2026

01 · LA VULNERABILIDAD

Una persona podía ver y cambiar una oportunidad ajena

ENLYCE recibe desde la página web los datos de quienes quieren comprar, arrendar, vender o administrar un inmueble. Cada solicitud se convierte en una oportunidad dentro del CRM.

El problema aparecía cuando alguien enviaba un correo que ya estaba registrado. La respuesta mostraba información de la oportunidad existente, incluido su identificador interno. Después, ese identificador y el mismo correo bastaban para cambiar los datos del inmueble sin iniciar sesión.

En palabras simples. el sistema trataba dos datos visibles —correo e identificador— como si fueran una contraseña. No lo eran.

Ejemplo

Ana había dejado su correo para vender un apartamento. Otra persona conocía ese correo, lo enviaba de nuevo y ENLYCE le devolvía la referencia interna de Ana. Con esa referencia podía cambiar el barrio, el precio o el mensaje asociado a la oportunidad.

Nombre de la falla

Esta vulnerabilidad se conoce como acceso indebido a un registro. En seguridad también recibe los nombres BOLA o IDOR, pero lo importante no es la sigla: una persona podía actuar sobre información que no le pertenecía.

Repetimos el recorrido de un atacante, usando datos de prueba

La prueba se hizo únicamente en el entorno local de ENLYCE y con información inventada. No se usaron datos de clientes reales.

1. Creamos una oportunidad de prueba desde el formulario público de propietarios.
2. Volvimos a enviar el mismo correo, como lo haría alguien que conoce el correo de otra persona.
3. Observamos que la respuesta revelaba el nombre, el correo, el estado y la referencia interna de la oportunidad ya existente.
4. Usamos esa referencia y el correo en la opción pública para completar datos del inmueble.
5. Revisamos el CRM y comprobamos que el barrio y el mensaje habían sido modificados.

Prueba repetible. convertimos el recorrido anterior en una prueba automática. Antes de la corrección falló exactamente donde debía: el sistema revelaba el registro y aceptaba el cambio.

La señal definitiva

ANTES	AHORA
La respuesta del contacto repetido incluía datos de la oportunidad.	La prueba exigía que no apareciera ningún dato interno.
La dirección antigua aceptaba el cambio y respondía correctamente.	La prueba exigía que esa dirección ya no existiera.

03 · QUÉ PODÍA CAUSAR

El riesgo no era teórico

El fallo permitía afectar la información comercial y personal que usa el equipo para atender a un cliente. No daba acceso completo al CRM, pero sí abría una puerta pública hacia oportunidades concretas.

Consecuencias

- Exponer el nombre, correo, estado y referencia interna de una oportunidad existente.
- Cambiar el tipo de inmueble, ciudad, barrio, precio esperado, mensaje o canal de contacto.
- Confundir al asesor con información falsa y contaminar el historial comercial.
- Hacer que una persona reciba una atención basada en datos que nunca proporcionó.
- Debilitar la confianza en el tratamiento de datos personales realizado por ENLYCE.

Gravedad. se clasificó como crítica porque combinaba dos problemas: primero revelaba cómo encontrar la ficha y luego permitía modificarla.

04 · CÓMO LA SOLUCIONAMOS

Quitamos la identidad de la respuesta y usamos un permiso temporal

La solución no consistió en esconder el identificador visualmente. Se cambió la forma en que funciona el proceso.

ANTES	AHORA
El sistema devolvía la ficha existente.	La respuesta es neutra e igual para todos.
Mostraba identificador, nombre, correo y estado.	No entrega ningún dato de la oportunidad.
Correo + identificador permitían cambiar la ficha.	Se usa una clave aleatoria creada para esa solicitud.
La autorización no vencía ni se consumía.	La clave dura 20 minutos y funciona una sola vez.
La dirección vulnerable seguía disponible.	La dirección antigua fue eliminada.

Cómo funciona ahora

1. La persona envía sus datos básicos.
2. ENLYCE responde sin decir si el correo ya existía y sin mostrar información interna.
3. Si la solicitud es nueva, entrega una clave aleatoria para completar los datos opcionales.
4. La base de datos guarda solamente una huella de esa clave, no la clave original.
5. Al usarla, la clave queda consumida. Repetirla no cambia nada.

Analogía. la clave funciona como una tarjeta temporal de hotel: abre una sola puerta, durante poco tiempo y deja de servir después de usarse.

05 · CÓMO COMPROBAMOS LA CORRECCIÓN

Intentamos el mismo ataque otra vez

Después del cambio repetimos el recorrido original y añadimos controles para evitar que la falla regrese en una actualización futura.

- Un correo repetido recibe una respuesta genérica: no aparecen datos ni referencias de la oportunidad anterior.
- La dirección vulnerable con el identificador ya no existe.
- Una clave inventada no modifica ninguna oportunidad.
- Una clave válida completa la solicitud correcta.
- La misma clave, usada por segunda vez, no vuelve a modificar la información.

COMPROBACIÓN	RESULTADO
Controles de endurecimiento	5 de 5 superados
Suite completa de ENLYCE	408 de 408 superadas
Verificación de la página web	Sin errores de tipos

Resultado final. el ataque documentado ya no permite descubrir ni modificar una oportunidad ajena. La prueba queda dentro del proyecto para vigilar que la protección no se pierda.